VULNERABILITY ASSESSMENT REPORT

1. Introduction

This report presents the results of a vulnerability assessment conducted on the target website **http://demo.testfire.net**. The purpose of this assessment is to identify security weaknesses, evaluate associated risks, and provide recommendations to improve the security posture of the application.

2. Target Website

URL: http://demo.testfire.net
The application is a test website designed for security learning and vulnerability assessment practice.

3. Tools Used

• Nmap – For port scanning and service detection
• OWASP ZAP – For automated vulnerability scanning
• Browser DevTools – For manual inspection

4. Findings

4.1 Open Ports Analysis

The Nmap scan identified the following open ports:
• Port 80 (HTTP) – Open
• Port 443 (HTTPS) – Open
• Port 8080 (HTTP alternative port) – Open

Risk Level: Medium to High
Explanation: Open ports increase the attack surface of the system. Port 8080 is commonly used for alternate services and may expose additional vulnerabilities if not secured properly.
Recommendation: Close unnecessary ports such as 8080, use firewall rules to restrict access, and enforce HTTPS.

4.2 Server Information Exposure

The server is identified as **Apache Tomcat/Coyote JSP engine 1.1**.
Risk Level: Medium
Explanation: Exposing server details allows attackers to identify the technology stack and exploit known vulnerabilities.
Recommendation: Hide server version information and configure proper security settings.

4.3 Insecure Communication (HTTP)

The application supports HTTP communication (Port 80).
Risk Level: Medium
Explanation: HTTP is not encrypted and is vulnerable to interception attacks such as Man-in-the-Middle (MITM).
Recommendation: Redirect all traffic to HTTPS and disable HTTP access.

4.4 Web Vulnerabilities (OWASP ZAP Scan)

1. Cross Site Scripting (XSS)
Risk: High – Allows attackers to inject malicious scripts.

2. SQL Injection
Risk: High – Attackers can manipulate database queries.

3. Absence of Anti-CSRF Tokens
Risk: Medium – Enables unauthorized actions.

4. Missing Security Headers
Risk: Low–Medium – CSP and X-Content-Type missing.

5. Cookie Security Issues
Risk: Medium – Missing SameSite attribute.

5. Risk Summary

Vulnerability	Risk Level
SQL Injection	High
XSS	High
Open Ports	Medium–High
Server Exposure	Medium
HTTP Usage	Medium
Missing Headers	Low–Medium

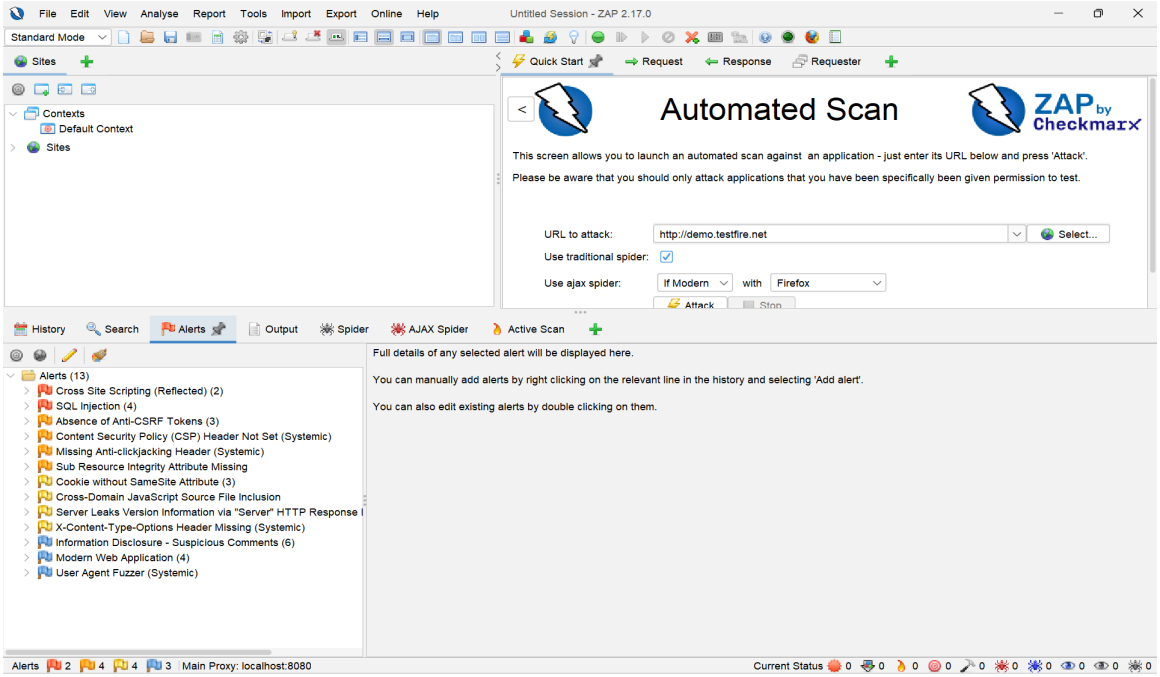
6. Conclusion

The vulnerability assessment revealed several critical and moderate security issues within the application. High-risk vulnerabilities such as SQL Injection and Cross-Site Scripting must be addressed immediately. By implementing the recommended security measures, the overall security can be improved.

7. Screenshots

```
C:\Users\HARISH>nmap -sV demo.testfire.net
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-21 21:50 India Standard Time
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.16s latency).
Other addresses for demo.testfire.net (not scanned): 64:ff9b::413d:8975
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE   VERSION
80/tcp   open   http      Apache Tomcat/Coyote JSP engine 1.1
443/tcp  open   ssl/http  Apache Tomcat/Coyote JSP engine 1.1
8080/tcp open   http      Apache Tomcat/Coyote JSP engine 1.1
8443/tcp closed https-alt

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 62.30 seconds
```



Altoro Mutual | Ask Gemini

Not secure demo.testfire.net

Sign In | Contact Us | Feedback | Search Go

AltoroMutual

DEMO SITE ONLY

ONLINE BANKING LOGIN | PERSONAL | SMALL BUSINESS | INSIDE ALTORO MUTUAL

PERSONAL
- Deposit Product
- Checking
- Loan Products
- Cards
- Investments & Insurance
- Other Services

SMALL BUSINESS
- Deposit Products
- Lending Services
- Cards
- Insurance
- Retirement
- Other Services

INSIDE ALTORO MUTUAL
- About Us
- Contact Us
- Locations
- Investor Relations
- Press Room
- Careers
- Subscribe

Online Banking with FREE Online Bill Pay
No stamps, envelopes, or checks to write give you more time to spend on the things you enjoy.

Real Estate Financing
Fast. Simple. Professional. Whether you are preparing to buy, build, purchase land, or construct new space, let Altoro Mutual's premier real estate lenders help with financing. As a regional leader, we know the market, we understand the business, and we have the track record to prove it

Business Credit Cards
You're always looking for ways to improve your company's bottom line. You want to be informed, improve efficiency and control expenses. Now, you can do it all - with a business credit card account from Altoro Mutual.

Retirement Solutions
Retaining good employees is a tough task. See how Altoro Mutual can assist you in accomplishing this feat through effective Retirement Solutions.

Privacy and Security
The 2000 employees of Altoro Mutual are dedicated to protecting your privacy and security. We pledge to provide you with the information and resources that you need to help secure your information and keep it confidential. This is our promise.

Win a Samsung Galaxy S10 smartphone
Completing this short survey will enter you in a draw for 1 of 5 Samsung Galaxy S10 smartphones! We look forward to hearing your important feedback.

Privacy Policy | Security Statement | Server Status Check | REST API | © 2026 Altoro Mutual, Inc.

This web application is open source! *Get your copy from GitHub and take advantage of advanced features*

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to https://www.hcl-software.com/appscan/.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.